1. Executive Summary

1.1 Objective

The primary objective of this Penetration Testing and Vulnerability Assessment (VAPT) was to identify, quantify, and document security vulnerabilities within the target environment. This assessment simulates real-world attack vectors to evaluate the security posture and provide actionable remediation strategies to protect sensitive data and maintain system integrity.

1.2 Scope of Assessment

- **Target Scope:** 192.168.56.101 (Metasploitable 2 Virtual Machine)
- **Testing Methodology:** Black Box
- **Assessment Timeline:** 01/10/2026 to 30/10/2026
- **Out of Scope:** Denial of Service (DoS) attacks, Social Engineering, Physical Security.

1.3 High-Level Findings

During the assessment, a total of 4 vulnerabilities were identified. The breakdown of the security flaws based on their severity is as follows:

- **Critical :** 1
- **High :** 2
- **Medium:** 1
- **Low :** Implicit

The most significant risk identified was a backdoor in the FTP service which could allow an attacker to gain root shell access and gain the highest authority over the target system.

2. Vulnerability Mapping & Risk Matrix (CVSS & OWASP Mapping)

This section maps the discovered vulnerabilities using the Common Vulnerability Scoring System (CVSS v3.1) and aligns them with the OWASP Top 10 categories to provide a standardized risk overview.

Vulnerability Name	OWASP Category	CVSS 3.1 Base Score	Severity
SQL Injection	A03:2021-Injection	9.8	Critical
vsftpd 2.3.4 Backdoor	A07:2021-Identification and Authentication Failures	9.8	Critical
Broken Object Level Authorization (IDOR/BOLA)	A04:2021-Insecure Design	8.1	High
Stored Cross-Site Scripting (XSS)	A03:2021-Injection	6.1	Medium

3. Technical Findings & Patch Guidelines

3.1 SQL Injection (SQLi) - Authentication Bypass

- **Vulnerability Description:** The login interface failed to sanitize user input, allowing direct injection of SQL commands into the database query structure.
- **Impact:** An attacker can bypass administrative authentication without valid credentials, gaining full access to the backend system and sensitive user data.
- **OWASP Category:** A03:2021-Injection
- **CVSS 3.1 Base Score:** 9.8 (Critical)
- **Patch Guidelines:**
    1. Implement parameterized queries or prepared statements in the backend authentication logic to treat user input as data, not executable code.
    2. Employ a secure database driver that natively supports binding parameters.

3.2 vsftpd 2.3.4 Backdoor Execution

- **Vulnerability Description:** The File Transfer Protocol (FTP) service contained a known backdoor mechanism triggered by sending a specific character sequence (a smiley face emoticon) to port 21.
- **Impact:** Successful execution opens a command shell on port 4444, granting the attacker root-level access and complete control over the target operating system.
- **OWASP Category:** A07:2021-Identification and Authentication Failures
- **CVSS 3.1 Base Score:** 9.8 (Critical)
- **Patch Guidelines:**
    1. Remove the compromised vsftpd version immediately and upgrade the FTP service to the latest secure release.
    2. Restrict direct unencrypted FTP access and mandate the use of SFTP over SSH for secure file transfers.

3.3 Cross-Site Scripting (XSS) - Stored

- **Vulnerability Description:** The application accepted and stored arbitrary script tags in the product review section without proper output encoding or sanitization.
- **Impact:** Malicious scripts execute within the browser of any user viewing the compromised comments, potentially leading to session hijacking or cookie theft.
- **OWASP Category:** A03:2021-Injection
- **CVSS 3.1 Base Score:** 6.1 (Medium)
- **Patch Guidelines:**
    1. Sanitize all user-supplied input upon ingress using a trusted HTML filtering library (e.g., DOMPurify).
    2. Implement strict contextual output encoding before rendering dynamic content within the User Interface.

3.4 Broken Object Level Authorization (BOLA/IDOR)

- **Vulnerability Description:** The order tracking mechanism failed to validate whether the logged-in user owned the requested order identifier. Modifying the URL parameters exposed unauthorized tracking results.
- **Impact:** Unauthorized disclosure of proprietary order details, pricing information, and personal customer data across user accounts.
- **OWASP Category:** A01:2021-Broken Access Control
- **CVSS 3.1 Base Score:** 8.1 (High)
- **Patch Guidelines:**
    1. Implement strict server-side authorization checks to verify that the session user ID matches the requested resource owner before returning payload data.
    2. Replace easily guessable sequential identifiers with cryptographically secure, unpredictable UUIDs.

4. Remediation Timelines & Final Steps

To ensure a structured and prioritized security improvement process, the following remediation timeframes should be observed for the identified vulnerabilities:

- **Critical Severity (e.g., SQLi, vsftpd Backdoor):** Immediate patch application and system isolation within 24 to 48 hours.
- **High Severity (e.g., BOLA/IDOR):** Remediation plan implementation and patches deployed within 1 to 2 calendar weeks.
- **Medium Severity (e.g., XSS):** Vulnerability resolution during the next standard update or deployment cycle.

Conclusion

The successful completion of these remediation steps will significantly harden the target environment against potential exploitation and align the system with industry standard security practices. The report is now ready for final review.

5. Certification & Final Submission

Upon successful review and validation of all remediation strategies and documented vulnerabilities, this comprehensive report serves as the final submission required to earn the Cybersecurity and Ethical Hacking Credential.

Link :- https://github.com/EthicalVivek8859/Cybersecurity-Internship-Tasks